1.2.4 Inefficiency

Multi-tenanted, distributed systems, especially those used across different organizations, face unique authorization challenges. Static access control methods were developed before distributed and cloud computing was prevalent.

Consider an electronic health record (EHR) system used by doctors, nurses, patients, administrators, and insurance processors. Doctors are allowed to update patient records, nurses can view and edit vitals and medications, and administrators can only view billing details. Doctors and nurses should only be allowed to work on records of patients in their department. Time is also a factor. We may restrict nurses from having access unless they're on shift, while doctors should have access anytime. And the entire system must consider patient consent to comply with regulations.

ACLs and groups are inefficient in this scenario in terms of both resources and time. ACLs require one list per patient record or set of patient records, depending on the system. Groups grow combinatorially as doctors, nurses, and administrators need to be in multiple departments or roles. This is even more of a problem when role assignments are transient. Patient consent further compounds this, requiring separate role-based mappings for unique consent scenarios. Managing these and dealing with exceptions takes time. Coordinating list sharing across systems and organizations, or involving multiple stakeholders in list membership decisions, is a time-consuming process.

1.2.5 Auditability

Static systems are hard to audit to determine policy and regulatory compliance. As we've discussed, most organizations are subject to numerous, sometimes overlapping regulations that inform access control decisions.

Take, for instance, a bank that must comply with both the Sarbanes-Oxley Act (SOX) (https://www.investopedia.com/terms/s/sarbanesoxleyact.asp) and the European Union's General Data Protection Regulation (GDPR) (https://commission.europa.eu/law/law-topic/data-protection/legal-